

1. OVERVIEW

An overview of Requirement 12 (“Have an InfoSec Policy”), and its sub-requirements.



REQ. 12: INFOSEC POLICY

REQ. 12: INFOSEC POLICY **OVERVIEW**

Requirement 12 (Support Information Security with Organizational Policies and Programs) is about having an InfoSec policy, and related documentation.

- This requirement is mostly about management, not technology, but it's the backbone of everything else;
- Remember all those “document and enforce” sub-requirements? This is all of those - and more;

The requirement mostly focuses on:

- Knowing your PCI-DSS scope (and complying with it);
- Documenting policies on end users, controls, threats, incidents, and all elements related to the PCI-DSS;
- Maintaining document from third-party service providers (TPSPs) and their own PCI-DSS compliance;
- Have IR procedures to respond to incidents immediately;

REQ. 12: INFOSEC POLICY **OVERVIEW**

The sub-requirements for this requirement include:

- 12.1 A comprehensive information security policy that governs and provides direction for protection of the entity's information assets is known and current.
- 12.2 Acceptable use policies for end-user technologies are defined and implemented.
- 12.3 Risks to the cardholder data environment are formally identified, evaluated, and managed.
- 12.4 PCI DSS compliance is managed.
- 12.5 PCI DSS scope is documented and validated.
- 12.6 Security awareness education is an ongoing activity.
- 12.7 Personnel are screened to reduce risks from insider threats.
- 12.8 Risk to information assets associated with third-party service provider (TPSP) relationships is managed.
- 12.9 Third-party service providers (TPSPs) support their customers' PCI DSS compliance.
- 12.10 Suspected and confirmed security incidents that could impact the CDE are responded to immediately.





REQ. 12: INFOSEC POLICY

REQ. 12: INFOSEC POLICY **OVERVIEW**

12.1 A comprehensive information security policy that governs and provides direction for protection of the entity's information assets is known and current

- There must be an InfoSec policy, that is maintained, published, disseminated;
- Key roles and responsibilities must be included, including responsibility for information security by a CISO/equivalent;
- There must be a significant review every 12 months;

This is usually tested through:

- Examining the policy, including specific details;
- Interviewing personnel;
- Validating the policy is properly managed and updated;
- Validating personnel (including CISO) acknowledge roles;

REQ. 12: INFOSEC POLICY

OVERVIEW

12.2 Acceptable use policies for end-user technologies are defined and implemented

- Basically, what software and hardware can employees use?
This must be formally defined;
- There must be explicit approval for given software and hardware, what it can be used for, and an inventory of it;

This is usually tested through:

- Examining the acceptable use policies and documentation;
- Interviewing personnel to ensure that these authorizations and prohibitions are, actually, enforced;





REQ. 12: INFOSEC POLICY

REQ. 12: INFOSEC POLICY **OVERVIEW**

12.3 Risks to the cardholder data environment are formally identified, evaluated, and managed. Focuses on four areas:

- Requirements that performed periodically: when and why?
- Requirements met with customized controls: the same;
- What crypto protocols do we use and why?
- What software/hardware do we use, and why?

This is usually tested through:

- Examining the risk analyses - and the processes for them;
- Examining documentation for customized/flexible controls;
- Examining documentation for cryptographic protocols and interviewing personnel on their usage;
- Examining documentation for HW/SW in use, and interviewing personnel on their usage;

REQ. 12: INFOSEC POLICY **OVERVIEW**

12.4 PCI DSS compliance is managed (service providers only):

- There must be a full PCI-DSS compliance program in the organization, including accountability and a charter;
- This program must be fully reviewed every 3 months, in terms of personnel performing their tasks and operations, logs, configuration reviews, standards, responding to alerts, and similar operations;

This is usually tested through:

- Examining documentation, including executive validation for the PCI-DSS program;
- Interviewing personnel + examining policies, logs and documents to validate that tasks are being performed;
- Validating review results, remediation, and sign-off;





REQ. 12: INFOSEC POLICY

REQ. 12: INFOSEC POLICY **OVERVIEW**

12.5 PCI DSS scope is documented and validated

- This requirement is about knowing what is in your CDE, and what changes in terms of it;
- It includes all of the elements in scope, including data flows, places where we store/process CHD, networks and segmentation, connections from third-party entities, etc;
- Basically, knowing exactly what the PCI-DSS scope is;

This is usually tested through:

- Examining inventories, diagrams, documentation;
- Interviewing personnel to validate how up-to-date inventories and diagrams are;
- Validating that the PCI-DSS scope contains all of the required elements (inventories, diagrams, and elements required);

REQ. 12: INFOSEC POLICY **OVERVIEW**

12.6 Security awareness education is an ongoing activity

- There must be a training program for security awareness in the organization, and people must receive that training;
- The training must include the major threats and vulnerabilities to the CDE, such as phishing, social engineering activities, and elements such as acceptable use of software and hardware;

This is usually tested through:

- Examining the program itself to validate what it includes, its content, training reviews, and interviewing personnel;
- Examining attendance records, the methods used to train personnel, the materials used, and acknowledgement by trained personnel;





REQ. 12: INFOSEC POLICY

REQ. 12: INFOSEC POLICY **OVERVIEW**

12.7 Personnel are screened to reduce risks from insider threats

- Basically, HR must screen personnel before they are hired to work in the CDE (or transferred from less sensitive areas of the organization to roles that deal with the CDE);
- Background checks, suspicious activity checks, or whatever makes sense for your jurisdiction and current conditions;

This is usually tested through:

- Interviewing HR representatives to ensure that the screening is, in fact, conducted, within local laws;
- Validating screening records for hired personnel;

REQ. 12: INFOSEC POLICY **OVERVIEW**

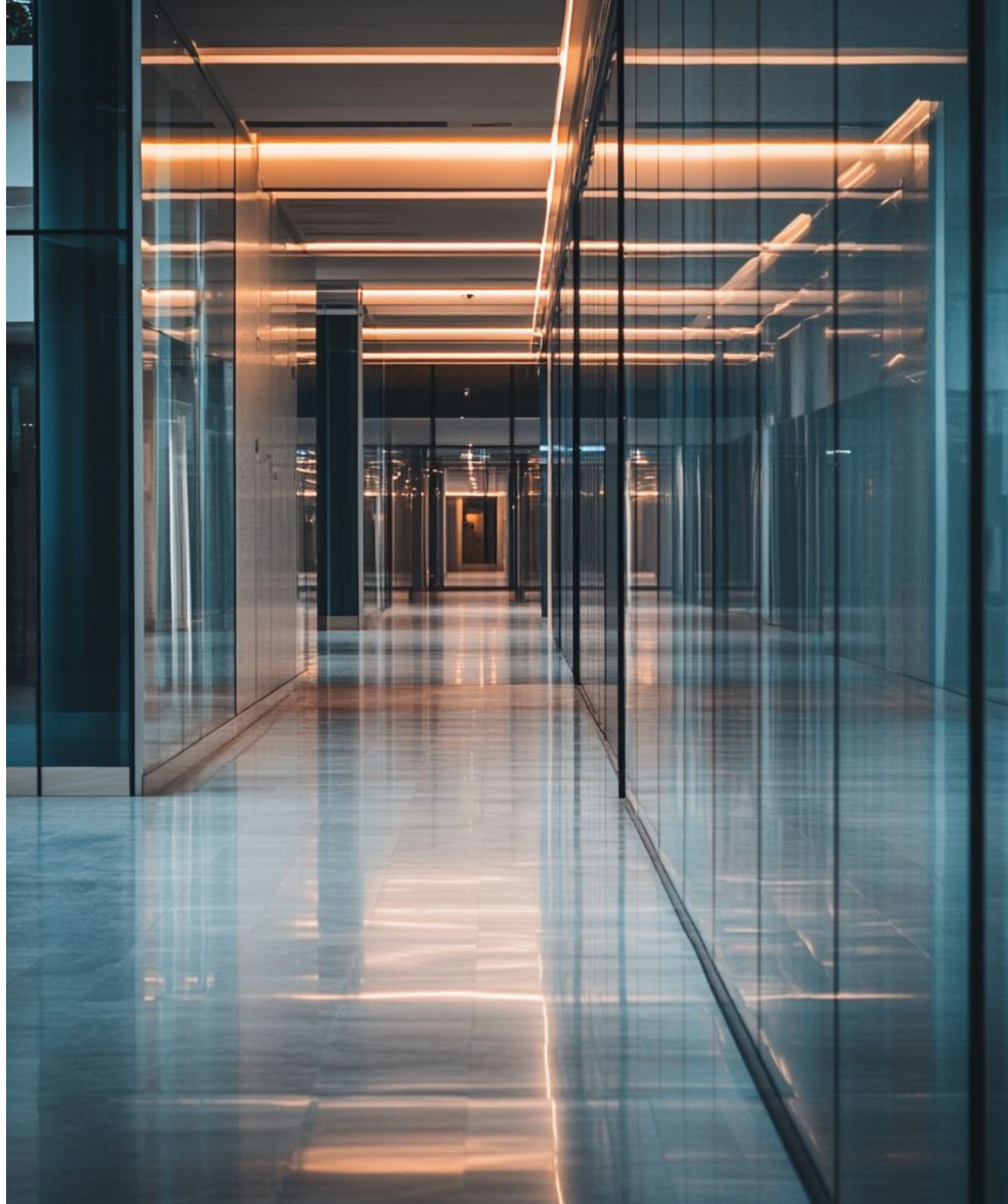
12.8 Risk to information assets associated with third-party service provider (TPSP) relationships is managed

- Whatever third-party companies touch our CHD must be inventoried and managed, essentially;
- We must inventory them, perform screening before engaging with them, validate their compliance, and receive acknowledge of PCI-DSS compliance, for example;

This is usually tested through:

- Interviewing people and examining the documentation, including the inventory of TPSPs, the contents of this inventory, and the actual acknowledgments by them;
- Verifying the processes for creating and maintaining this documentation, and managing TPSPs themselves;





REQ. 12: INFOSEC POLICY

REQ. 12: INFOSEC POLICY **OVERVIEW**

12.9 Third-party service providers (TPSPs) support their customers' PCI DSS compliance (service providers only):

- This requirement is for service providers only. Basically, in this case, your TPSPs have to ensure that they not only will protect the CHD data that you have, but also that of your own clients;
- It's about inventorying, managing, and acknowledging as in the previous sub-requirement, but for your clients;

This is usually tested through:

- Similar to the previous point - examining documents, interviewing people, checking the process to create documentation - but TPSPs protecting not just your data, but your clients' data, too;

REQ. 12: INFOSEC POLICY

OVERVIEW

12.10 Suspected and confirmed security incidents that could impact the CDE are responded to immediately

- There must be a very detailed IR plan including containment and mitigation, roles and responsibilities, communication, disclosures, backups, and much more;
- There must be people assigned 24/7 to respond to incidents, and they must be periodically trained;

This is usually tested through:

- Examining the IR plan and its components;
- Interviewing people and examining logs of past incidents;
- Examining documentation, role assignments, and training logs/materials for the personnel available 24/7;





REQ. 12: INFOSEC POLICY

REQ. 12: INFOSEC POLICY **OVERVIEW**

How can we summarize, then, this requirement?

- We need to have an overall information security policy.
Requirements, controls, roles, responsibilities, and more;
- We must formally manage risks in certain categories such as flexible requirement controls, customized controls, etc;
- We must keep the PCI-DSS scope defined and updated, with all the documentation and elements that entails;
- We must educate our personnel, including on threats such as social engineering, and on acceptable uses of SW/HW;
- We must manage TPSPs, both in terms of screening and inventorying them, but also receiving acknowledgement they will protect our data;
- We must have a ready IR plan to deal with incidents, defining immediate actions, communication, and more;

REQ. 12: INFOSEC POLICY

OVERVIEW

EXAMPLES

/01 MERGES WITH PRACTICES

A lot of the documentation here merges with existing cybersecurity practices. IR plans, data flow diagrams, and others may already exist - just need refining here.

/02 AGAIN, COMMON SENSE

Many of these policies, such as acceptable use of systems and background checks on hired personnel, don't need specifics - just some thought put into it.

/03 NO AGREEMENT

The declaration of handling and safeguarding CHD data by a service provider is essential. If they do not provide it (or if you don't!), then something's wrong.

REQ. 12: INFOSEC POLICY

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization develops a clear and concise policy on protecting CHD, including employee responsibilities and acceptable users of systems handling CHD;
- Basic security awareness training is provided to all staff upon hiring, and annually;
- An IR plan is implemented, including actions/contacts;

E-COMMERCE STORE

- The organization develops detailed policies covering all aspects of InfoSec, from data handling to access control, password management and more;
- An extensive IR plan is documented and updated, outlining procedures for detecting/responding to/recovering from security incidents, tested annually;

HOTEL CHAIN

- The organization establishes standardized, company-wide security policies, across all hotel locations, to ensure consistent protection of CHD;
- The organization reviews and updates all security policies and procedures annually + on all significant changes;

PAYMENT PROCESSOR

- The organization develops an extensive set of InfoSec governance policies, standards and procedures, encompassing all possible industry best practices and regulatory requirements;
- A comprehensive IR plan is developed with defined roles and procedures for dozens of different threat types, with regular drills;

REQ. 12: INFOSEC POLICY

OVERVIEW

KEY TAKEAWAYS

/01 INFOSEC POLICY

This requirement is, essentially, about having an information security policy, managing risks, managing compliance, managing incidents, and best practices.

/03 12.2 ACCEPTABLE USES

Acceptable software and hardware must be formally defined, as well as the acceptable uses for these by personnel, explicitly.

/05 12.4 MANAGED COMPLIANCE

Service providers must have PCI-DSS program, with a charter, accountabilities and responsibilities, and every 3 months must ensure tasks are being well performed.

/02 12.1 THE INFOSEC POLICY

An information security policy must exist, must be updated and disseminated, formal roles and responsibilities must exist, and it must be updated.

/04 12.3 RISK ANALYSIS

We must have risk analyses for flexible requirement controls, for customized requirement controls, for crypto protocols, and for HW/SW used.

/06 12.5 SCOPE VALIDATED

The PCI-DSS scope must be documented and updated, including many elements such as data flows, all controls, all data storage locations, and much more.

REQ. 12: INFOSEC POLICY

OVERVIEW

KEY TAKEAWAYS

/07 12.6 ONGOING AWARENESS

An awareness and training program must not just exist and be delivered, but also be updated. It must cover phishing/social engineering + acceptable uses.

/08 12.7 PERSONNEL SCREENING

Personnel who are hired for - or transferred to - positions dealing with CHD data must be screened in whichever ways make sense for our location.

/09 12.8 TPSP RISKS

We must inventory all TPSPs, how they deal with our CHD and for what, manage them, screen them, and obtain acknowledge they will protect our data.

/10 12.9 TPSP COMPLIANCE

For service providers, we must perform not just all of the previous tasks in terms of TPSPs protecting our CHD, but also those of our clients.

/11 12.10 INCIDENT RESPONSE

We must have a formal IR plan detailing the actions, the roles, the communications and disclosures, and we must have a team available 24/7 for responses.